

SIMATS ENGINEERING ASSESSMENT TOOL 2

COURSE NAME: CRYPTOGRAPHY AND NETWORK SECURITY
COURSE CODE: CSA51

COURSE OUTCOME COVERED

CO2: Analyze Public Key crypto system strategies using RSA and key Exchange for Encryption algorithm to strengthen information security. (BL4,BL5)

Scenario-Based : 20%

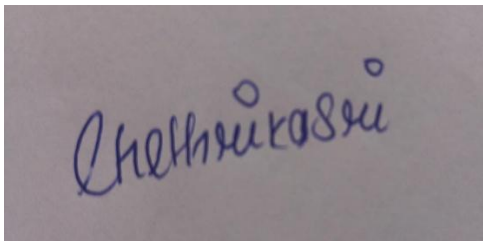
Total Marks: 50

Annexure A

Code of Conduct:

I ____Chethrikasri KM(192511112)____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

A photograph of a handwritten signature in blue ink on a light-colored surface. The signature is written in a cursive style and reads "Chethrikasri".

1. Secure Password Storage in Web Applications

Scenario:

A web application stores user passwords and needs to protect them against database breaches.

A. Explain why storing plaintext passwords is insecure.

Storing passwords in plaintext means saving the user's original password exactly as it is entered, without any encryption or hashing. This is one of the most dangerous security practices because if the application's database is compromised, an attacker can immediately read every user's password.

The major risks of storing plaintext passwords include:

- **Immediate Exposure:** If hackers gain access to the database, they can view all passwords without any effort.
- **Unauthorized Account Access:** Attackers can use the stolen passwords to log in to users' accounts and perform unauthorized activities.
- **Password Reuse Attacks:** Many users reuse the same password across multiple websites. Attackers can use the stolen passwords to access email accounts, banking applications, and social media accounts.
- **Identity Theft:** Personal information stored in user accounts can be stolen and misused for fraudulent activities.
- **Loss of User Trust:** A password leak damages the organization's reputation and reduces customer confidence.
- **Legal and Financial Consequences:** Organizations may face legal penalties, financial losses, and regulatory actions for failing to protect sensitive user information.

Therefore, storing passwords in plaintext is highly insecure because anyone who accesses the database can instantly obtain every user's password

B. Suggest a secure method for storing passwords and justify your choice.

A secure method is to store passwords using a salted cryptographic hash generated by password-hashing algorithms such as crypt, Argon2, or PBKDF2.

How the method works:

1. The user creates a password during registration.
2. The system generates a unique random value called a salt.
3. The password and salt are combined.
4. A secure hashing algorithm (such as crypt or Argon2) converts the password into a fixed-length hash.
5. Only the hashed password and the salt are stored in the database. The original password is never stored.
6. During login, the entered password is hashed again using the same salt and compared with the stored hash. If both hashes match, the user is authenticated.

Justification:

- **Protects Passwords:** Even if the database is stolen, attackers cannot directly determine the original passwords because only hashes are stored.
- **Prevents Rainbow Table Attacks:** The use of a unique salt ensures that identical passwords produce different hash values.
- **Resists Brute-Force Attacks:** Algorithms like crypt and Argon2 are intentionally slow, making password guessing attacks much more difficult.
- **One-Way Process:** Hash functions cannot be reversed to recover the original password.
- **Industry Standard:** Modern web applications widely use crypt, Argon2, or PBKDF2 because they provide strong security against password theft.

Conclusion

Storing passwords in plaintext exposes users to severe security risks. Using salted password hashing with algorithms such as crypt, Argon2, or PBKDF2 provides strong protection against database breaches by ensuring that original passwords are never stored and are extremely difficult for attackers to recover.

2. Digital Signature for Document Authentication

Scenario:

A company wants to ensure that official documents sent electronically are authentic and unaltered.

A. Explain how digital signatures can be used in this scenario.

A digital signature is a cryptographic technique used to verify the authenticity of the sender and ensure that an electronic document has not been modified during transmission. It uses public key cryptography, where the sender has a private key and the receiver uses the corresponding public key.

Working of a Digital Signature:

1. The sender prepares the official document.
2. A cryptographic hash function (such as SHA-256) generates a unique hash value (message digest) for the document.
3. The sender encrypts this hash using their private key, creating the digital signature.
4. The digital signature is attached to the document and sent to the receiver.
5. Upon receiving the document, the receiver uses the sender's public key to decrypt the digital signature and obtain the original hash.
6. The receiver also generates a new hash from the received document using the same hash function.
7. The two hash values are compared:
 - If both hashes are identical, the document is authentic and has not been altered.
 - If the hashes differ, the document has been modified or the signature is invalid.

Thus, digital signatures allow the receiver to verify both the identity of the sender and the integrity of the document.

B. Justify how this method ensures both integrity and non-repudiation.

1. Integrity

Integrity ensures that the document has not been changed after it was signed.

- Before sending, a hash of the document is generated.
- When the receiver gets the document, a new hash is calculated.
- If even a single character in the document has been modified, the new hash will be completely different from the original hash.
- Since the hash values will not match, the receiver immediately knows that the document has been tampered with.

Therefore, digital signatures guarantee that the document remains unchanged during transmission.

2. Non-Repudiation

Non-repudiation means that the sender cannot deny sending or signing the document.

- The digital signature is created using the sender's private key, which is known only to the sender.
- Anyone can verify the signature using the sender's public key, but no one else can create a valid signature without the private key.
- As a result, the sender cannot later claim that they did not send or sign the document.

This provides proof of the sender's identity and prevents denial of authorship.

Advantages of Digital Signatures

- Verifies the authenticity of the sender.
- Ensures the document has not been modified.
- Prevents forgery and impersonation.
- Provides legal proof of document ownership.
- Builds trust in electronic communication.

Conclusion

Digital signatures are an effective solution for authenticating electronic documents. By combining hashing with public key cryptography, they ensure integrity by detecting any modification to the document and provide non-repudiation by proving that the document was signed using the sender's private key. Therefore, digital signatures are widely used for securing official documents, contracts, financial transactions, and government communications.

3. Preventing Replay Attacks in Online Transactions

Scenario:

An online payment system is vulnerable to replay attacks where attackers resend previously captured transactions.

A. Explain how replay attacks occur.

A replay attack is a type of cyberattack in which an attacker intercepts a valid data transmission, such as a payment request or authentication message, and maliciously sends the same message again at a later time. Since the message is genuine, the system may process it again if it does not verify whether the request is new or has already been used.

How a Replay Attack Works:

1. A user initiates an online payment transaction.
2. The payment request is transmitted over the network.
3. An attacker captures the transmitted message using network monitoring techniques.
4. Instead of modifying the message, the attacker stores it and resends the exact same transaction later.
5. If the payment system cannot distinguish between the original and the repeated request, it processes the transaction again.
6. This may result in duplicate payments, unauthorized fund transfers, or repeated execution of the same transaction.

Effects of Replay Attacks

- Unauthorized duplicate transactions.
- Financial loss to users or organizations.
- Fraudulent access to online services.
- Loss of customer trust in the payment system.
- Compromise of transaction security and reliability.

B. Suggest a cryptographic technique to prevent such attacks and justify your answer.

A highly effective technique to prevent replay attacks is to use nonces (numbers used only once) or timestamps, together with Message Authentication Codes (MACs) or digital signatures.

How the Method Works:

1. Every transaction is assigned a unique nonce (a random number used only once) or a timestamp indicating the exact time of the request.

2. The nonce or timestamp is included in the transaction message before it is authenticated.
3. A MAC or digital signature is generated for the complete message, including the nonce or timestamp.
4. When the server receives the transaction, it verifies the MAC or digital signature and checks whether the nonce has already been used or whether the timestamp is still valid.
5. If the nonce is repeated or the timestamp has expired, the server rejects the transaction as a replay attack.

Justification

- **Unique Nonces:** Since each nonce is used only once, replayed messages are easily detected and rejected.
- **Timestamps:** They ensure that only recent transactions are accepted, preventing attackers from resending old messages.
- **Message Authentication:** MACs and digital signatures verify that the message has not been modified and originates from an authorized sender.
- **Improved Security:** Even if an attacker captures a valid transaction, it cannot be successfully replayed because the nonce or timestamp will no longer be valid.

Conclusion

Replay attacks occur when attackers capture and retransmit valid transaction messages to perform unauthorized actions. Using nonces or timestamps along with Message Authentication Codes (MACs) or digital signatures effectively prevents these attacks by ensuring that every transaction is unique, authenticated, and accepted only once. This significantly improves the security of online payment systems and protects users from duplicate or fraudulent transactions.

4. Secure Communication over Public Wi-Fi

Scenario:

A user accesses sensitive information using a public Wi-Fi network without encryption.

A. Identify the risks involved in this scenario.

Public Wi-Fi networks are often unsecured, meaning that data transmitted between the user's device and the internet may not be encrypted. This allows attackers connected to the same network to intercept or manipulate the communication. As a result, users who access sensitive information such as banking details, passwords, or personal data over public Wi-Fi are exposed to various security threats.

Risks of Using Public Wi-Fi Without Encryption

1. Eavesdropping (Data Interception):

Attackers can capture network traffic and read sensitive information such as usernames, passwords, emails, and credit card details.

2. Man-in-the-Middle (MITM) Attacks:

An attacker secretly places themselves between the user and the website, intercepting or altering the communication without the user's knowledge.

3. Session Hijacking:

Attackers can steal session cookies and gain unauthorized access to a user's online accounts without knowing the password.

4. Identity Theft:

Personal and financial information obtained through intercepted communications can be misused for fraudulent activities.

5. Malware Distribution:

Cybercriminals may exploit insecure public networks to spread malicious software to connected devices.

6. Loss of Privacy:

Browsing activity, login credentials, and confidential information can be monitored by attackers, compromising the user's privacy.

B. Recommend a secure communication method and justify how it protects user data.

The recommended method for secure communication over public Wi-Fi is to use HTTPS (HyperText Transfer Protocol Secure) along with a Virtual Private Network (VPN).

How the Method Works

1. HTTPS (TLS/SSL Encryption):

- HTTPS encrypts all data exchanged between the user's browser and the website using the **Transport Layer Security (TLS)** protocol.
- Even if attackers intercept the communication, they cannot read or modify the encrypted data.

2. Virtual Private Network (VPN):

- A VPN creates an encrypted tunnel between the user's device and the VPN server.
- All internet traffic passes through this secure tunnel, protecting it from hackers on the same Wi-Fi network.
- The VPN also hides the user's IP address, improving privacy and anonymity.

Justification

- **Confidentiality:** Encryption ensures that only the sender and the intended receiver can read the transmitted information.
- **Protection Against Eavesdropping:** Attackers cannot understand encrypted data even if they capture network traffic.
- **Prevents MITM Attacks:** TLS certificates verify the identity of websites, reducing the risk of fake or malicious websites intercepting communication.
- **Secures Sensitive Transactions:** Login credentials, banking information, and personal data remain protected while using public Wi-Fi.
- **Enhances Privacy:** A VPN conceals the user's online activity and prevents unauthorized monitoring.

Conclusion

Using public Wi-Fi without encryption exposes users to serious security threats such as eavesdropping, Man-in-the-Middle attacks, session hijacking, malware infections, and identity theft. By using HTTPS and a VPN, all transmitted data is encrypted, ensuring confidentiality, integrity, and privacy. These technologies significantly reduce the risk of cyberattacks and provide secure communication over public networks.

5. Data Integrity in Cloud Storage

Scenario:

An organization stores critical data on a cloud server and wants to ensure that the data is not altered.

A. Explain how hashing can be used to verify data integrity.

Hashing is a cryptographic technique used to verify the integrity of data. A hash function, such as SHA-256, converts data of any size into a fixed-length value called a hash value or message digest. Even a small change in the original data produces a completely different hash value, making hashing an effective method for detecting unauthorized modifications.

How Hashing Works

1. Before storing a file in the cloud, the organization generates a hash value using a secure hash algorithm such as SHA-256.
2. The generated hash value is stored securely, either in a separate database or by the organization.
3. The original file is uploaded to the cloud server.
4. Whenever the file is downloaded or accessed, the system generates a new hash value for the retrieved file.
5. The newly generated hash is compared with the original stored hash.
6. If both hash values are identical, the file has not been modified and its integrity is confirmed.
7. If the hash values are different, it indicates that the file has been altered, corrupted, or tampered with during storage or transmission.

Advantages of Hashing

- Detects any unauthorized modification to data.
- Ensures data integrity during storage and transmission.
- Generates a unique hash value for every file.
- Fast and efficient for verifying large files.
- Widely used in cloud storage, digital forensics, and cybersecurity.

B. Suggest an additional mechanism to enhance trust and justify your answer.

An effective additional mechanism is the use of Digital Signatures.

How Digital Signatures Enhance Trust

1. Before uploading the file, the organization generates a hash of the data.
2. The hash is encrypted using the organization's private key, creating a digital signature.
3. The file and its digital signature are stored in the cloud.
4. When the file is retrieved, the receiver uses the organization's public key to verify the digital signature.
5. The receiver also generates a new hash of the retrieved file and compares it with the decrypted hash.
6. If both hashes match, the file is confirmed to be authentic and unchanged.

Justification

- **Ensures Authenticity:** Confirms that the data was uploaded by the legitimate organization.
- **Provides Integrity:** Any modification to the file changes its hash value, causing signature verification to fail.
- **Supports Non-Repudiation:** Since only the owner possesses the private key, they cannot deny signing the data.
- **Builds Trust:** Users can confidently verify that the cloud-stored data is genuine and has not been tampered with.

Conclusion

Hashing is an efficient method for verifying the integrity of data stored in the cloud by comparing the original and current hash values. However, hashing alone cannot identify who created or modified the data. Combining SHA-256 hashing with digital signatures provides stronger security by ensuring data integrity, authenticity, and non-repudiation, making cloud storage more secure and trustworthy.

RUBRICS FOR CALCULATION:

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand

